



I.E.S. Ribera del Tajo

TÉCNICO SUPERIOR EN ADMINISTRACIÓN DE
SISTEMAS INFORMÁTICOS EN RED

TAREA PIMAS 02

*Proyecto intermodular de Administración de
Sistemas Informáticos en Red*

Autor:
Gabriel Abellán Rodríguez

5 de mayo de 2026

Índice

1. Introducción	3
2. Módulos Implicados	4
3. Estudio de Mercado y Viabilidad Comercial	5
4. Análisis DAFO (Debilidades, Amenazas, Fortalezas y Oportunidades)	5
5. Catálogo de Servicios Digitales	8
5.1. Comercio Electrónico B2C	8
5.2. Gestión Logística	8
5.3. Atención al Cliente mediante Inteligencia Artificial	8
5.4. Autenticación y Verificación de Identidad	8
5.5. Políticas de Restricción y Calidad de Servicio (QoS)	9
5.6. Diseño de Interfaz Asíncrono	9
6. Arquitectura de Persistencia de Datos	10
6.1. Esquema Relacional	10
7. Stack Tecnológico y Desarrollo Web	11
7.1. Definición del Stack	11
7.2. Diseño Adaptativo (Responsive Design)	11
8. Continuidad de Negocio: Backup y Recuperación (Disaster Recovery)	12
9. Integración de Sistemas Empresariales (API/ERP)	13
10. Estudio de Viabilidad Técnica y Económica	13
10.1. Modelo de Ingresos (Revenue Model)	13
10.2. Estructura Jurídico-Fiscal	13
10.3. Plan de Inversiones (CAPEX)	14
10.4. Escalabilidad Operativa	14
11. Cumplimiento Normativo y Privacidad (RGPD/LOPD)	15
12. Prevención de Riesgos Laborales (PRL) en Entornos IT	16
13. Infraestructura y Segmentación de Red	17
13.1. Enrutamiento y Segmentación (VLANs)	17

14.Sistemas Operativos y Directorios Corporativos	18
14.1. Directorio Activo y Políticas Centralizadas	18
15.Contenerización de Servicios (Docker / Linux)	19
15.1. Arquitectura de Microservicios	19
15.2. Ventajas Operativas y Escalabilidad Horizontal	19
16.Memoria Técnica Detallada: Infraestructura de Alta Disponibilidad	20
16.1. Introducción y Objetivos	20
16.2. Detalle de los Sistemas Implementados	20
16.2.1. Firewall Perimetral (pfSense)	20
16.2.2. Balanceador de Carga (HAProxy)	20
16.2.3. Granja de Servidores Web (Application Nodes)	21
16.2.4. Clúster de Bases de Datos (MariaDB Active-Active)	21
16.3. Metodología de Implementación	22
17.Monitorización y Telemetría de la Infraestructura	23
17.1. Parámetros de Auditoría Sensible	23
18.Bastionado de Servidores (Hardening) y Ciberseguridad Activa	23
18.1. Aseguramiento de los Protocolos de Administración (SSH)	24
18.2. Criptografía en Tránsito (TLS/SSL y Let's Encrypt)	24
18.3. Cortafuegos de Nivel de Host (UFW / IPtables)	25
19.Anexo: Galería de la Página Web	26
19.1. Navegación e Inicio de la Tienda	26
19.2. Proceso de Compra	27
19.3. Verificación y Acceso	28
19.4. Herramientas de Inteligencia Artificial	30
19.5. Atención al Cliente	33
19.6. Vista Móvil (Diseño Responsive)	34

1. Introducción

El presente proyecto tiene como objetivo fundamental el diseño, desarrollo e implementación de una plataforma web transaccional orientada a la comercialización e información de juegos de cartas coleccionables (JCC). Este sector ha experimentado un crecimiento sostenido en los últimos ejercicios, tanto en volumen de usuarios como en el consumo de productos asociados. La solución propuesta no solo constituye un entorno de comercio electrónico B2C (Business-to-Consumer) para la adquisición de productos y accesorios, sino que también actúa como un repositorio documental y formativo para usuarios de diversos niveles de experiencia.

La plataforma se estructura en módulos funcionales diferenciados: una tienda en línea para la comercialización de productos, un apartado de guías técnicas introductorias para los principales sistemas de juego del mercado, y una sección de divulgación normativa. Este enfoque centraliza servicios y conocimientos que habitualmente se encuentran fragmentados en la red.

A nivel de interfaz de usuario (UI) y experiencia de usuario (UX), el diseño se basa en principios de accesibilidad, usabilidad y diseño adaptativo (Responsive Web Design), garantizando la correcta visualización en dispositivos de escritorio y móviles. Adicionalmente, se ha implementado soporte multi-idioma (español e inglés) para facilitar la internacionalización del servicio.

El desarrollo de esta infraestructura tecnológica constituye la aplicación práctica de los conocimientos adquiridos durante el ciclo formativo de grado superior en Administración de Sistemas Informáticos en Red (ASIR). Esto abarca desde el despliegue de la capa de presentación (frontend) y lógica de negocio (backend), hasta el diseño de la persistencia de datos, la configuración de topologías de red seguras, la contenerización de servicios y el establecimiento de políticas de alta disponibilidad.

2. Módulos Implicados

El desarrollo arquitectónico e implementación técnica del proyecto se fundamentan en las siguientes áreas de conocimiento:

- **Administración de Sistemas Operativos:** Despliegue y configuración de entornos de servidor (Windows Server y distribuciones GNU/Linux). Implementación de rutinas de automatización (scripts Bash) para la gestión de copias de seguridad de la base de datos (Disaster Recovery).
- **Planificación y Administración de Redes:** Diseño de la topología lógica, segmentación mediante VLANs y configuración de reglas de enrutamiento y cortafuegos para aislar entornos críticos.
- **Fundamentos de Hardware:** Planificación de los requisitos físicos para la infraestructura de servidores y sistemas de almacenamiento necesarios para garantizar el rendimiento operativo.
- **Inglés:** Integración de funcionalidades de internacionalización en la plataforma, permitiendo la conmutación dinámica del contenido entre español e inglés.
- **Lenguaje de Marcas y Sistemas de Gestión de Información:** Construcción de la capa de presentación mediante HTML5 y CSS3, aplicando metodologías de diseño modular. Integración de interactividad asíncrona mediante JavaScript (peticiones Fetch y notificaciones tipo toast).
- **Implantación de Aplicaciones Web:** Configuración de servidores web (Apache/Nginx) y despliegue del entorno de ejecución PHP para la lógica de negocio.
- **Gestión de Bases de Datos:** Diseño e implementación del esquema relacional en motores MySQL/MariaDB. Uso de procedimientos almacenados y disparadores (Triggers) para garantizar la integridad referencial y automatizar procesos internos.
- **Seguridad y Alta Disponibilidad:** Aplicación de políticas de bastionado (Hardening), cifrado asimétrico para accesos (SSH), configuración de túneles seguros (TLS/SSL) y diseño de infraestructuras redundantes.
- **Itinerario Personal para la Empleabilidad:** Formulación del plan de Prevención de Riesgos Laborales (PRL) asociado al entorno tecnológico y logístico del proyecto.

3. Estudio de Mercado y Viabilidad Comercial

Público Objetivo: El segmento de mercado principal comprende usuarios de entre 15 y 35 años, con perfiles orientados al coleccionismo y al juego competitivo de la franquicia Pokémon. La fase inicial de despliegue logístico se acotará al territorio nacional (España), con proyecciones de escalabilidad hacia el mercado europeo (Cross-border e-commerce) a medio plazo.

Análisis de la Competencia: El ecosistema de venta de JCC presenta una alta saturación. Para establecer una ventaja competitiva, la plataforma propuesta enfatiza una experiencia de usuario (UX) superior y tiempos de respuesta logísticos optimizados. Entre los principales actores del mercado se identifican:

- **Canales Oficiales (Pokémon Center):** Presentan alta fiabilidad, pero adolecen de precios premium y frecuentes roturas de stock.
- **Plataformas Marketplace (Cardmarket):** Ofrecen gran volumen, pero la naturaleza descentralizada incrementa los riesgos de fraude y encarece los costes logísticos (múltiples envíos).
- **Retail Local:** Disponen de proximidad, pero generalmente aplican márgenes comerciales elevados que restan competitividad frente a soluciones digitales puras.

Demanda: El mercado de coleccionables mantiene una curva de demanda sostenida y alcista, caracterizada por su resiliencia incluso en periodos de contracción económica, impulsada por la nostalgia y el factor especulativo de los activos (cartas).

Estrategia de Penetración (Marketing): Se priorizará el marketing de contenidos en plataformas de alta tasa de retención (Instagram, YouTube Shorts) para canalizar tráfico orgánico. Simultáneamente, se aplicarán técnicas de optimización en motores de búsqueda (SEO) y marcado semántico para mejorar la indexabilidad de la plataforma.

4. Análisis DAFO (Debilidades, Amenazas, Fortalezas y Oportunidades)

Debilidades:

- Dependencia inicial en la gestión manual de operaciones logísticas, control de inventarios y atención de incidencias.
- Posicionamiento nulo en la fase de lanzamiento (Start-up), requiriendo un esfuerzo intensivo para capturar cuota de mercado frente a competidores consolidados.
- Alta dependencia del flujo de lanzamientos (novedades) dictado por el fabricante.
- Requerimiento de capital de trabajo (Working Capital) elevado para el acopio inicial de inventario con márgenes competitivos.

Amenazas:

- Roturas de cadena de suministro por parte de los distribuidores mayoristas, que podrían interrumpir el flujo de ventas.
- Riesgo operativo derivado de la introducción de falsificaciones ("proxies") de alta fidelidad en el mercado secundario de compraventa.
- Fluctuaciones en las tarifas de los operadores logísticos (e.g., Correos, SEUR), que pueden impactar negativamente en el margen de beneficio neto.

Fortalezas:

- Producto de alta demanda y liquidez, con una base de consumidores altamente fidelizada y dispuesta a la compra recurrente.
- Estructura de costes operativos fijos iniciales mínimos (Bootstrapping), al centralizar las operaciones en un entorno logístico propio y prescindir temporalmente de locales comerciales.
- Arquitectura web de grado empresarial (Premium UI/UX, integración de IA, notificaciones asíncronas), que transmite confiabilidad y modernidad frente a plataformas heredadas (Legacy).

Oportunidades:

- Expansión continua del mercado de coleccionables en el ecosistema digital europeo.
- Posibilidad de generar sinergias mediante la creación de contenido viral en redes sociales para reducir los costes de adquisición de clientes (CAC).

- Escalabilidad horizontal del catálogo hacia productos adyacentes de alto margen (accesorios de protección, álbumes, merchandising).

5. Catálogo de Servicios Digitales

La arquitectura del servicio ha sido diseñada para minimizar la fricción en el proceso de conversión (compra) y proporcionar valor añadido mediante soluciones tecnológicas avanzadas.

5.1. Comercio Electrónico B2C

El servicio central consiste en una plataforma de e-commerce transaccional. La base de datos segmenta el catálogo en dos líneas principales: productos sellados (cajas, sobres) y el mercado secundario de activos individuales (cartas sueltas).

5.2. Gestión Logística

Se ha implementado un flujo de gestión de pedidos integrado, diseñado para coordinar la expedición a través de operadores logísticos nacionales, garantizando el acondicionamiento protector ("packaging" especializado) para prevenir la depreciación del activo durante el tránsito.

5.3. Atención al Cliente mediante Inteligencia Artificial

Para optimizar los recursos de soporte, se han integrado servicios basados en Inteligencia Artificial mediante consumo de APIs RESTful:

- **PimasBot AI:** Asistente virtual impulsado por los modelos fundacionales de Google Gemini, capaz de procesar lenguaje natural (NLP) para resolver consultas operativas de Nivel 1.
- **PokeLens (Computer Vision):** Módulo de reconocimiento de imágenes que, apoyándose en la IA de visión computacional, clasifica y detecta automáticamente tarjetas subidas por el usuario, automatizando la búsqueda en el catálogo.

5.4. Autenticación y Verificación de Identidad

Se ha implementado un flujo de autenticación robusto. La plataforma requiere la validación de cuentas mediante el envío de códigos de un solo uso (OTP) a través de un servidor de correo saliente (SMTP). Este mecanismo previene el alta de cuentas sintéticas y garantiza la trazabilidad de los usuarios.

5.5. Políticas de Restricción y Calidad de Servicio (QoS)

Para garantizar la disponibilidad de la plataforma y mitigar riesgos de seguridad (como ataques de denegación de servicio a nivel de aplicación - Capa 7 OSI), se aplican principios de acceso condicional. Funcionalidades de alto consumo computacional o integraciones con APIs externas (Carrito de compra, llamadas a Gemini AI) están restringidas exclusivamente a sesiones autenticadas. Esta política de Rate Limiting implícita previene la saturación de CPU/RAM y el agotamiento de cuotas de facturación de servicios de terceros por parte de agentes automatizados (Bots).

5.6. Diseño de Interfaz Asíncrono

La experiencia de usuario se ha optimizado mediante el uso de JavaScript asíncrono (AJAX/Fetch) y CSS3 avanzado. Las interacciones con la base de datos (e.g., adición de ítems al carrito) no requieren la recarga del documento (Document Object Model), operando en segundo plano e informando al usuario mediante componentes visuales no intrusivos ("Toast Notifications") y micro-animaciones.

6. Arquitectura de Persistencia de Datos

La persistencia de información se soporta sobre un motor de bases de datos relacional (MySQL/MariaDB). En la fase de desarrollo se ha optado por entornos de prueba locales, con un plan de migración hacia instancias contenerizadas para la fase de producción, garantizando así la inmutabilidad del entorno y eliminando dependencias tipo XAMPP.

6.1. Esquema Relacional

El modelo de datos garantiza la integridad referencial y se apoya en restricciones (Constraints) y disparadores lógicos (Triggers) para automatizar el control de concurrencia y los flujos de inventario.

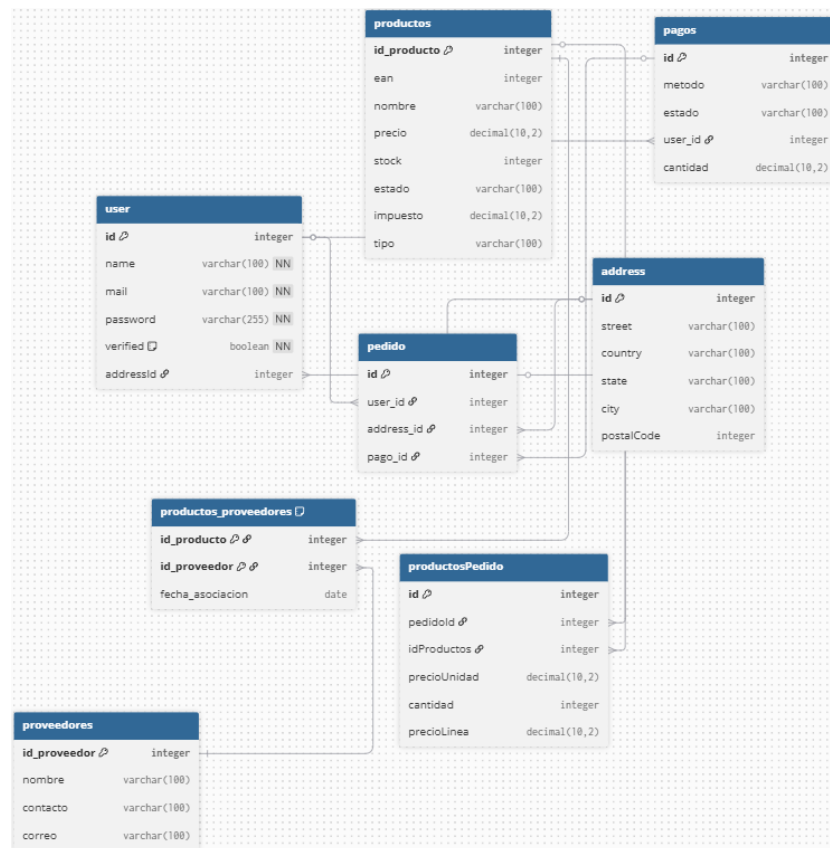


Figura 1: Diagrama Entidad-Relación de la base de datos.

7. Stack Tecnológico y Desarrollo Web

La solución adopta una arquitectura cliente-servidor clásica, segmentada en las capas de presentación, lógica de negocio y persistencia.

7.1. Definición del Stack

- **Capa de Presentación (Frontend):** Desarrollada en HTML5 semántico y CSS3 puro para garantizar un renderizado ligero y de alto rendimiento (Zero-dependency architecture). Se integra JavaScript nativo (Vanilla JS) para gestionar el estado de la interfaz y las llamadas asíncronas.
- **Capa Lógica (Backend):** Procesamiento soportado por PHP, gestionando el control de sesiones seguras, la validación de entrada (Input sanitization) contra ataques de inyección SQL (SQLi) y Cross-Site Scripting (XSS). La gestión de contraseñas se implementa mediante funciones de derivación de claves criptográficas (BCRYPT).
- **Capa de Datos (SQL):** Desplegada sobre MySQL/MariaDB, utilizando sentencias preparadas (Prepared Statements) en PHP (PDO/MySQLi) para garantizar la seguridad transaccional.
- **Integración de Servicios de Terceros (APIs):** Conexiones asíncronas hacia infraestructuras Cloud (Google Gemini) para dotar a la plataforma de capacidades de inteligencia artificial generativa y visión computacional.

7.2. Diseño Adaptativo (Responsive Design)

El marco de estilos (CSS) se ha estructurado mediante la metodología de separación de responsabilidades (archivos independientes para tipografías, componentes, disposición espacial). Mediante el uso de consultas de medios ("Media Queries"), la interfaz se adapta fluidamente a distintas resoluciones, garantizando la operatividad (Mobile-First approach).

8. Continuidad de Negocio: Backup y Recuperación (Disaster Recovery)

La integridad y disponibilidad de la información son críticas. Se han establecido políticas de redundancia para prevenir la pérdida de datos ante fallos de hardware, errores humanos o compromisos de seguridad.

La estrategia de respaldos se automatiza a nivel de sistema operativo mediante tareas programadas (Cron jobs en Linux) y scripts Bash, encargados de ejecutar volcados (Dumps) de la base de datos a intervalos regulares. Estos archivos resultantes son comprimidos y almacenados en repositorios aislados de la red pública, posibilitando una restauración rápida (RTO/RPO optimizados) en caso de contingencia.

9. Integración de Sistemas Empresariales (API/ERP)

A medio plazo, la infraestructura tecnológica contempla la integración del entorno LAMP/LEMP de producción con plataformas de gestión de recursos empresariales (ERP) y soluciones Low-Code (e.g., Appian) utilizadas para la gestión logística de inventarios.

Esta integración se realizará mediante el diseño de una API RESTful, permitiendo la sincronización bidireccional de datos en formato JSON. Cuando se ejecute una transacción en la pasarela web, el servidor notificará automáticamente al sistema de gestión de almacén (WMS), automatizando el flujo de trabajo (Workflow) de recolección, empaquetado y envío.

10. Estudio de Viabilidad Técnica y Económica

10.1. Modelo de Ingresos (Revenue Model)

La viabilidad financiera del proyecto se estructura en tres verticales de negocio:

1. **Retail Tradicional (Producto Sellado):** Adquisición de inventario a distribuidores mayoristas (B2B) y comercialización a precio de venta recomendado (PVR), asegurando márgenes operativos predecibles.
2. **Mercado Secundario (Cartas Sueltas):** Constituye el núcleo de rentabilidad, basado en el arbitraje y la tasación experta del estado de los activos ("Grading"). Los márgenes brutos en esta vertical pueden alcanzar o superar el 50 %.
3. **Cross-Selling (Accesorios):** Comercialización de periféricos de protección y almacenamiento (fundas, carpetas). Estos productos actúan como complementos indispensables para el cliente, incrementando significativamente el valor medio del ticket de compra.

10.2. Estructura Jurídico-Fiscal

Para la fase de lanzamiento (Seed stage), la estructura jurídica más eficiente es el alta en el Régimen Especial de Trabajadores Autónomos (RETA). Esta figura minimiza las barreras de entrada burocráticas y evita la exigencia de inmovilización de capital social (como requeriría una S.L.), permitiendo la facturación legal, la liquidación del IVA y la deducción del Impuesto sobre

Sociedades/IRPF aplicable a los gastos de infraestructura IT y aprovisionamiento.

10.3. Plan de Inversiones (CAPEX)

La estimación del gasto de capital inicial (Capital Expenditure) necesario para el despliegue técnico y logístico se detalla a continuación:

Concepto de Inversión Inicial	Coste Estimado
Hardware de Red y Computación (Servidor, Switch L2/L3, Router)	1.300 €
Licenciamiento de Software (Windows Server u otros)	600 €
Infraestructura Cloud (Dominio y VPS Anual)	80 €
Aprovisionamiento de Inventario Inicial	2.500 €
Material Logístico y Embalaje	150 €
Total Inversión Inicial (CAPEX)	4.630 €

Tabla 1: Previsión de inversión de capital inicial (CAPEX).

El retorno de la inversión (ROI) se estima en un plazo de 18 meses. La asunción interna de las labores de administración de sistemas e ingeniería de software (In-house development) reduce drásticamente los gastos operativos (OPEX) asociados a la externalización.

10.4. Escalabilidad Operativa

El modelo de negocio nace bajo el concepto de Bootstrapping, centralizando temporalmente la logística y el alojamiento de los servidores perimetrales en instalaciones residenciales adaptadas para eliminar costes fijos de arrendamiento comercial.

No obstante, la infraestructura técnica y el modelo de negocio están diseñados para el escalado operativo. Ante el aumento sostenido del tráfico transaccional, se contemplan las siguientes fases de expansión:

1. Migración logística hacia naves industriales o centros de distribución urbanos (Hubs).
2. Contratación de personal operativo para el cumplimiento de pedidos (Fulfillment).
3. Transición de la infraestructura local a gabinetes enrackables estándar industriales (Rack 19") o migración completa hacia servicios IaaS (Infrastructure as a Service) en proveedores Cloud, asegurando ancho de banda simétrico garantizado.

11. Cumplimiento Normativo y Privacidad (RGPD/LOPI)

El diseño de la plataforma se fundamenta en el principio de "Privacidad por Diseño", garantizando el estricto cumplimiento del Reglamento General de Protección de Datos (RGPD) europeo y la normativa nacional equivalente.

- **Consentimiento Informado:** La arquitectura de registro incorpora validaciones explícitas (.opt-in") donde el usuario autoriza el tratamiento de sus datos de carácter personal, circunscritos exclusivamente a la finalidad logística y fiscal del servicio.
- **Cifrado en Reposo (Data at Rest):** Bajo ningún concepto las credenciales de acceso se almacenan en texto plano. Las contraseñas son sometidas a derivación criptográfica mediante el algoritmo BCrypt (con factor de coste adaptativo) antes de su inserción en la base de datos.
- **Protección contra Autenticación Automatizada:** Se han desplegado políticas de limitación de tasa (Rate Limiting) a nivel de la base de datos y aplicación para mitigar ataques de fuerza bruta o relleno de credenciales (Credential Stuffing). Tres fallos consecutivos en el proceso de autenticación desencadenan un bloqueo temporal de la cuenta ("Lockout" de 15 minutos).
- **Política de Rastreo (Cookies):** La plataforma minimiza la recopilación de telemetría. Se emplean exclusivamente cookies técnicas o de sesión, estrictamente necesarias para el mantenimiento del estado transaccional (autenticación y carrito de compra), sin utilizar rastreadores de terceros para perfiles publicitarios.

12. Prevención de Riesgos Laborales (PRL) en Entornos IT

Atendiendo a la naturaleza de las operaciones técnicas y logísticas, se establecen los siguientes protocolos preventivos:

- **Ergonomía y Riesgos Psicosociales (PVD):** Para mitigar la fatiga visual y musculoesquelética derivada del uso prolongado de Pantallas de Visualización de Datos, se prescribe el uso de mobiliario ergonómico certificado, pautas de descanso visual (Regla 20-20-20) e iluminación perimetral antideslumbrante en los puestos de ingeniería.
- **Higiene Postural en Logística:** La manipulación manual de cargas (recepción de inventario y expedición) se regirá por protocolos biomecánicos de levantamiento, manteniendo la verticalidad espinal para prevenir hernias o distensiones lumbares.
- **Seguridad Eléctrica en CPD (Centro de Proceso de Datos):** El mantenimiento preventivo y correctivo del hardware de red y servidores exigirá protocolos antiestáticos (descarga a tierra, pulseras ESD), retirada de elementos metálicos personales y la manipulación de fuentes de alimentación bajo condiciones de aislamiento térmico y eléctrico.

13. Infraestructura y Segmentación de Red

El diseño de la topología de red local (LAN) constituye el núcleo crítico del despliegue. La arquitectura se fundamenta en principios de defensa en profundidad y segmentación lógica para aislar los entornos de producción y mitigar los movimientos laterales en caso de compromiso.

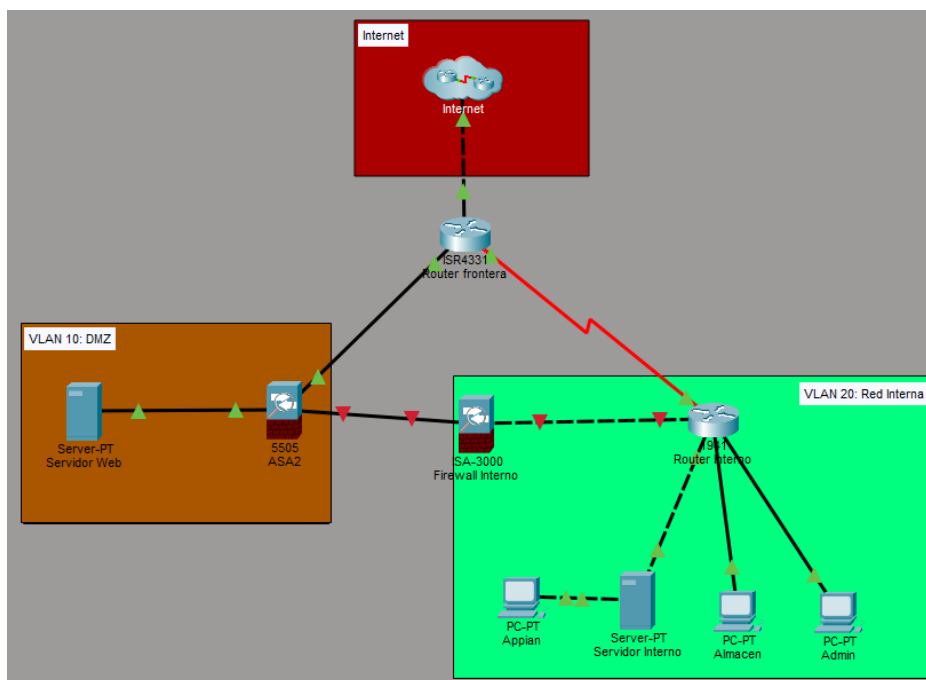


Figura 2: Topología de red y segmentación lógica.

13.1. Enrutamiento y Segmentación (VLANs)

La red corporativa se administra mediante switches gestionables de Capa 2/3, dividiendo el direccionamiento base (192.168.1.0/24) en zonas lógicas estancas:

- **Zona Desmilitarizada (DMZ / VLAN 10):** Red perimetral destinada al alojamiento del servidor web proxy/frontal. El cortafuegos perimetral (pfSense) aplica políticas de filtrado estrictas (NAT y Port Forwarding), permitiendo exclusivamente el tráfico entrante hacia los puertos HTTP (80) y HTTPS (443). El servidor expuesto permanece aislado del resto de la organización.
- **Red Interna Protegida (Backend / VLAN 20):** Segmento hermético donde residen los clústeres de bases de datos y los equipos de gestión

logística corporativa. Carece de visibilidad hacia Internet. Las comunicaciones entre la DMZ (aplicación web) y la VLAN 20 (base de datos) están rigurosamente auditadas mediante reglas estáticas de cortafuegos que permiten el flujo de datos unidireccional y cifrado solo sobre los puertos requeridos (ej. TCP 3306).

14. Sistemas Operativos y Directorios Corporativos

La arquitectura prescinde de entornos monolíticos de desarrollo (como XAMPP), apostando por infraestructuras distribuidas y robustas basadas en entornos Microsoft Windows Server para la gestión interna corporativa y distribuciones GNU/Linux para los sistemas productivos en red.

14.1. Directorio Activo y Políticas Centralizadas

Se desplegará una infraestructura de dominio basada en Windows Server 2022 para gestionar la identidad y el acceso en los equipos de gestión corporativa, implementando los siguientes servicios:

- **Servicios de Dominio de Active Directory (AD DS):** Implementación del "Principio de Menor Privilegio" (PoLP) mediante el Control de Acceso Basado en Roles (RBAC). Se estructuran Unidades Organizativas (OU) jerárquicas que impiden a usuarios no autorizados (ej. operarios de almacén) acceder a servidores de bases de datos o recursos compartidos críticos.
- **Resolución de Nombres DNS (Split-Brain DNS):** Configuración de zonas de búsqueda locales (ej. db.pokepimas.local) para abstraer la topología IP, garantizando que las migraciones de red o asignaciones DHCP no comprometan la configuración de los aplicativos internos.
- **Políticas de Grupo (GPO) como vector defensivo:** Despliegue de políticas de seguridad automatizadas aplicadas a nivel de equipo. Se deshabilitará preventivamente el almacenamiento masivo USB en terminales de operarios, erradicando los vectores de infección clásicos por malware físico y previniendo la exfiltración de datos (DLP).

15. Contenerización de Servicios (Docker / Linux)

Mientras que el plano de gestión interna opera bajo Windows Server, el entorno de producción web de alta disponibilidad se despliega íntegramente sobre infraestructuras GNU/Linux (Ubuntu Server 24.04 LTS), garantizando eficiencia, mínima huella de recursos y ausencia de superficies de ataque derivadas de interfaces gráficas (GUI).

15.1. Arquitectura de Microservicios

La pila tecnológica se empaqueta mediante el motor de Docker. A través de un orquestador declarativo (Docker Compose), la infraestructura se divide en contenedores aislados que corren en el mismo plano de host:

- **Contenedor de Aplicación (Web/PHP):** Utilización de imágenes inmutables (php:8.2-apache) optimizadas. Este contenedor gestiona el ciclo de vida de la aplicación y expone únicamente los puertos necesarios al proxy inverso.
- **Contenedor de Persistencia (MariaDB/MySQL):** Aislado operativamente del exterior mediante redes definidas por software (Docker Networks). Este contenedor no expone puertos al host físico local, asegurando que la base de datos solo es accesible desde el contenedor de aplicación en la misma red virtual.
- **Almacenamiento Persistente (Docker Volumes):** Los datos transaccionales se disocian del ciclo de vida efímero del contenedor. Se mapean volúmenes encriptados hacia el sistema de archivos del anfitrión, garantizando que reinicios, caídas o actualizaciones del motor no provoquen la pérdida de la información corporativa.

15.2. Ventajas Operativas y Escalabilidad Horizontal

La contenerización proporciona una portabilidad absoluta. Ante la eventual necesidad de escalar la plataforma, los contenedores sin estado (Stateless) pueden ser replicados instantáneamente. El diseño preparatorio es compatible con la migración futura hacia clústeres de orquestación masiva (Kubernetes), permitiendo el auto-escalado horizontal de los nodos de aplicación para gestionar picos volumétricos de tráfico transaccional.

16. Memoria Técnica Detallada: Infraestructura de Alta Disponibilidad

16.1. Introducción y Objetivos

Este proyecto se centra en el diseño e implementación de un entorno de servicios web y bases de datos con redundancia. El objetivo principal ha sido eliminar los puntos únicos de fallo (Single Points of Failure), garantizando que el servicio continúe operativo ante la caída de cualquier componente crítico.

16.2. Detalle de los Sistemas Implementados

16.2.1. Firewall Perimetral (pfSense)

El appliance virtual pfSense actúa como el guardián de toda la red. Su función en la arquitectura es:

- **Segmentación (VLANs/Subredes):** Aislamiento de las máquinas en redes distintas (DMZ de balanceo, servidores web de backend y clúster de bases de datos), forzando que el tráfico intra-red sea auditado por las listas de control de acceso (ACLs) del firewall.
- **NAT (Network Address Translation):** Redirección de las peticiones externas (puertos TCP 80/443) hacia la IP virtual (VIP) del balanceador de carga.
- **Filtrado de Egress (Salida):** Implementación de reglas restrictivas para limitar la conectividad exterior de los servidores, autorizando exclusivamente el tráfico necesario (resolución DNS, repositorios de parches), mitigando severamente los movimientos laterales o exfiltración en caso de brecha (Command and Control).

16.2.2. Balanceador de Carga (HAProxy)

El servicio HAProxy opera como el nodo director que distribuye la carga transaccional:

- **Distribución de Carga (Round Robin / Leastconn):** Reparte el tráfico entrante de forma dinámica entre el "pool" de servidores web, optimizando el uso de recursos computacionales.

- **Health Checks (Sondeo de Salud):** Supervisión activa de la operatividad de los servidores web (Capa 7 HTTP) y bases de datos (Capa 4 TCP). Ante respuestas anómalas o caídas temporales (Timeouts), el nodo afectado es retirado automáticamente del "pool" de balanceo.
- **Terminación SSL/TLS (Offloading):** Centralización de la validación criptográfica. El proxy recibe y descifra el tráfico HTTPS, reenviándolo en texto plano a la granja de servidores backend, aliviando la carga de procesamiento criptográfico (CPU overhead) en los nodos de aplicación y facilitando la rotación de certificados.

16.2.3. Granja de Servidores Web (Application Nodes)

Constituyen el clúster de alojamiento de la lógica PHP. La configuración de los nodos se diseña bajo un patrón de inmutabilidad (Stateless), garantizando la paridad entre servidores para que el balanceador conmute peticiones entre ellos de manera transparente y sin interrupciones de sesión ("Sticky sessions").

16.2.4. Clúster de Bases de Datos (MariaDB Active-Active)

El subsistema de mayor complejidad técnica recae en el aseguramiento de la disponibilidad de datos:

- **Replicación Multi-Master:** Topología circular donde múltiples nodos ejecutan escrituras y lecturas de forma concurrente. Se han configurado desplazamientos en los incrementos automáticos (`auto_increment_increment` y `auto_increment_offset`) para prevenir colisiones de claves primarias.
- **Sincronización por Identificador Global (GTID):** La réplica prescinde del método obsoleto por posición de archivo binario, basándose en la trazabilidad transaccional global (GTID). Este protocolo asegura la resolución de conflictos y evita el desajuste o pérdida de transacciones durante la resincronización de un nodo tras una interrupción eléctrica.
- **Resiliencia Operativa:** Habilitación de políticas `relay_log_recovery` que obligan al motor a purgar logs corruptos y solicitar las transacciones faltantes al nodo par tras reinicios inesperados ("Crash-safe replication").

16.3. Metodología de Implementación

El proceso de ingeniería se ha ejecutado bajo el paradigma de "Seguridad por Diseño":

- **Despliegue Base:** Definición de topología de red virtual, VLAN tagging y direccionamiento IP estático interno.
- **Aseguramiento Perimetral:** Configuración del firewall (Deny-All por defecto) de manera previa a la exposición de servicios web.
- **Orquestación Inversa:** Configuración de HAProxy como barrera y encaminador intermedio.
- **Sincronía de Estado:** Despliegue del túnel de replicación GTID, aplicando directivas estrictas de `bind-address` e implementando usuarios SQL con privilegios hiper-restringidos exclusivamente autorizados para ejecutar procesos de sincronización.

17. Monitorización y Telemetría de la Infraestructura

Garantizar la continuidad operativa requiere una observabilidad ininterrumpida de los componentes (SLA 24/7). Para este propósito, la infraestructura incorpora servicios centralizados de monitorización reactiva y proactiva basados en Zabbix.

17.1. Parámetros de Auditoría Sensible

El servidor de monitorización despliega agentes pasivos ("Zabbix Agents") en los nodos anfitriones, recolectando la telemetría del estado crítico de los recursos con alta frecuencia de sondeo:

- **Consumo Intensivo de CPU/RAM:** La detección de picos abruptos o desviaciones sostenidas en el consumo de memoria o procesamiento alerta sobre escenarios anómalos, tales como ataques de Denegación de Servicio (DDoS volumétricos o agostamiento de recursos) o fugas de memoria (Memory Leaks) en el código, permitiendo la intervención manual o escalado antes del colapso del nodo.
- **Cuotas de Almacenamiento y Repositorios de Backup:** La saturación silenciosa del disco duro constituye un vector crítico de interrupción en entornos Linux. Los agentes de Zabbix sondean constantemente las particiones y sistemas de archivos, generando alertas (Triggers de severidad naranja/alta) si la ocupación del almacenamiento destinado a copias de seguridad supera el 85 %, mitigando caídas operativas ("Kernel Panic." rotura de tablas SQL).
- **Sondeos Sintéticos (Web Scenarios):** Monitorización externa automatizada de la disponibilidad de la plataforma web. Zabbix ejecuta comprobaciones transaccionales completas (validación de respuestas HTTP 200 OK y tiempo de latencia). Ante divergencias o latencias superiores al umbral aceptable, el sistema notifica de forma inmediata al centro de operaciones a través de pasarelas de correo electrónico.

18. Bastionado de Servidores (Hardening) y Ciberseguridad Activa

Con anterioridad a la exposición pública de los servicios, los nodos anfitriones son sometidos a procesos rigurosos de "Hardening."operativo. El objeti-

vo es reducir drásticamente la superficie de ataque explotable de los demonios subyacentes.

18.1. Aseguramiento de los Protocolos de Administración (SSH)

El servicio de administración remota OpenSSH se configura mediante alteraciones restrictivas en sus archivos de configuración subyacentes (`/etc/ssh/sshd_config`):

1. **Inhabilitación de Autenticación Clásica y Escalada Root:** Prohibición absoluta de accesos remotos basados en contraseña (`PasswordAuthentication no`) y revocación de los permisos de acceso de red directos para el superusuario (`PermitRootLogin no`).
2. **Criptografía Asimétrica Obligatoria (Claves RSA/ED25519):** La autenticación requiere la presentación y correspondencia de pares de claves criptográficas de alta densidad provistas por el administrador, neutralizando la viabilidad de cualquier ataque de fuerza bruta o diccionario matemático.
3. **Protección Dinámica contra Intrusiones (Fail2Ban/IPS):** Despliegue del motor reactivo Fail2Ban para la auditoría de registros del sistema (`Syslog/Auth.log`). Ante patrones iterativos de intentos fallidos provenientes de una IP externa, el sistema interactúa de forma automatizada con el cortafuegos interno (`Netfilter/IPtables`) para aislar (Baneo) el nodo hostil en tiempo real.

18.2. Criptografía en Tránsito (TLS/SSL y Let's Encrypt)

La confidencialidad de la información transaccionada entre la capa de presentación y el cliente exige la obliteración del protocolo de texto plano (HTTP). Se ha establecido el cifrado integral de la comunicación:

- **Certificación Automatizada:** Implementación del protocolo ACME mediante el cliente Certbot para la expedición, renovación desatendida y firma de certificados digitales validados por la Autoridad de Certificación Let's Encrypt.
- **Redirección Forzosa (HSTS):** El balanceador de carga y los servidores web imponen políticas estrictas de redirección permanente (HTTP 301) forzando el transporte de datos exclusivamente a través del puerto seguro HTTPS (TCP 443), previniendo vulnerabilidades de degradación de protocolo y secuestros de sesión (Man In The Middle - MITM).

18.3. Cortafuegos de Nivel de Host (UFW / IPtables)

Con independencia del cortafuegos perimetral (pfSense), cada nodo anfitrión incluye una política de denegación predeterminada ("Deny-All / Drop by Default") en su cortafuegos lógico (Uncomplicated Firewall - UFW). Exclusivamente se autoriza la apertura (Allow In) de puertos esenciales: el servicio SSH ofuscado y el puerto de escucha del contenedor inverso, cerrando de forma absoluta el acceso directo a los restantes 65.535 puertos lógicos.

19. Anexo: Galería de la Página Web

A continuación se adjunta una recopilación de imágenes para mostrar el diseño y el funcionamiento visual y práctico de la página web terminada.

19.1. Navegación e Inicio de la Tienda



Figura 3: Página de inicio de la tienda web.

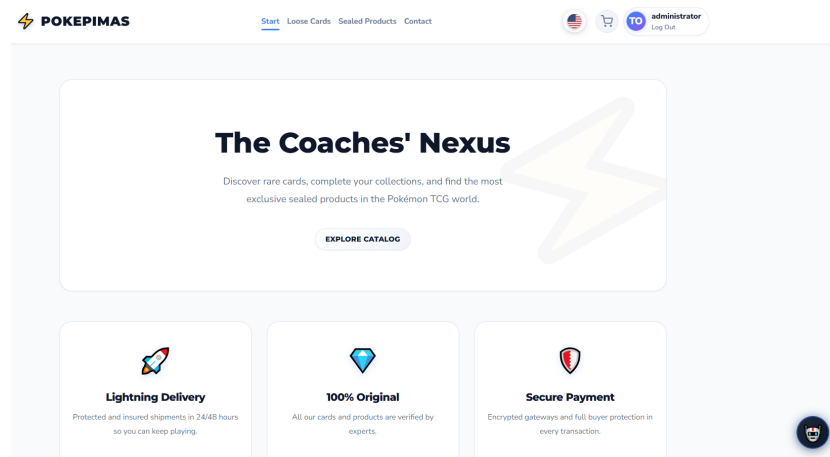


Figura 4: Página de inicio traducida al inglés mediante las banderas.

19.2. Proceso de Compra

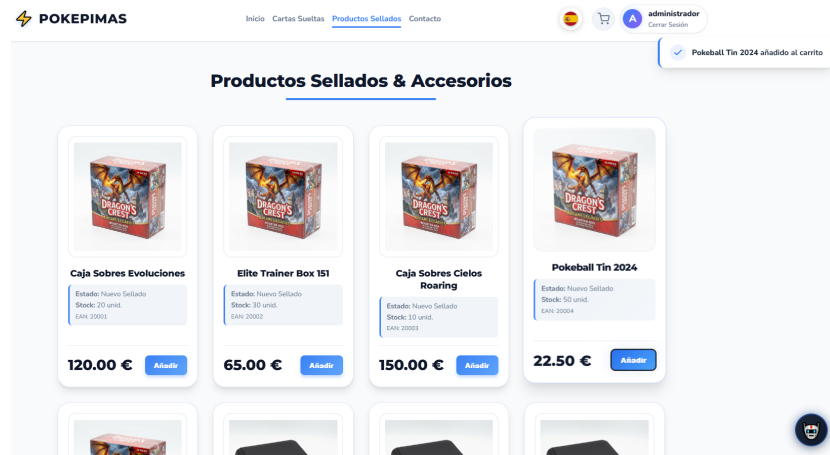


Figura 5: Vista de productos sellados al añadir un artículo al carrito.

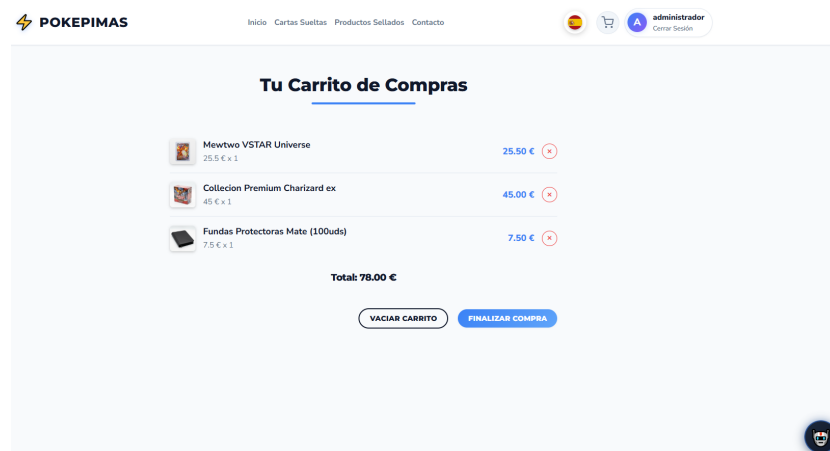


Figura 6: Carrito de compra con los productos añadidos.

19.3. Verificación y Acceso

Acceso Entrenador

USUARIO:

administrador

CONTRASEÑA:

....

ENTRAR

[¿No tienes cuenta? Regístrate aquí](#)

[Entrar sin registrarse](#)

Figura 7: Página de login con un inicio de sesión básico basado en un formulario.

Verifica tu cuenta de Entrenador - PokePimas External Recibidos x

[Redacted]

para mí ▼

Hola administrador,

Bienvenido a PokePimas.

Tu código secreto de verificación es: 948083

Introdúcelo en nuestra web para completar el registro y comenzar tu aventura.

Atentamente,

El Equipo de PokePimas (No responder a este correo).

Figura 8: Correo con el código de verificación de la cuenta.

Verificación de Cuenta

Te hemos enviado un correo electrónico con un código de 6 dígitos. Escríbelo abajo para continuar tu viaje.

CÓDIGO SECRETO:

0 0 0 0 0 0

VERIFICAR Y ENTRAR

[Volver al Inicio](#)

Figura 9: Página donde debemos meter el código que nos ha llegado para completar la verificación de la cuenta.

19.4. Herramientas de Inteligencia Artificial

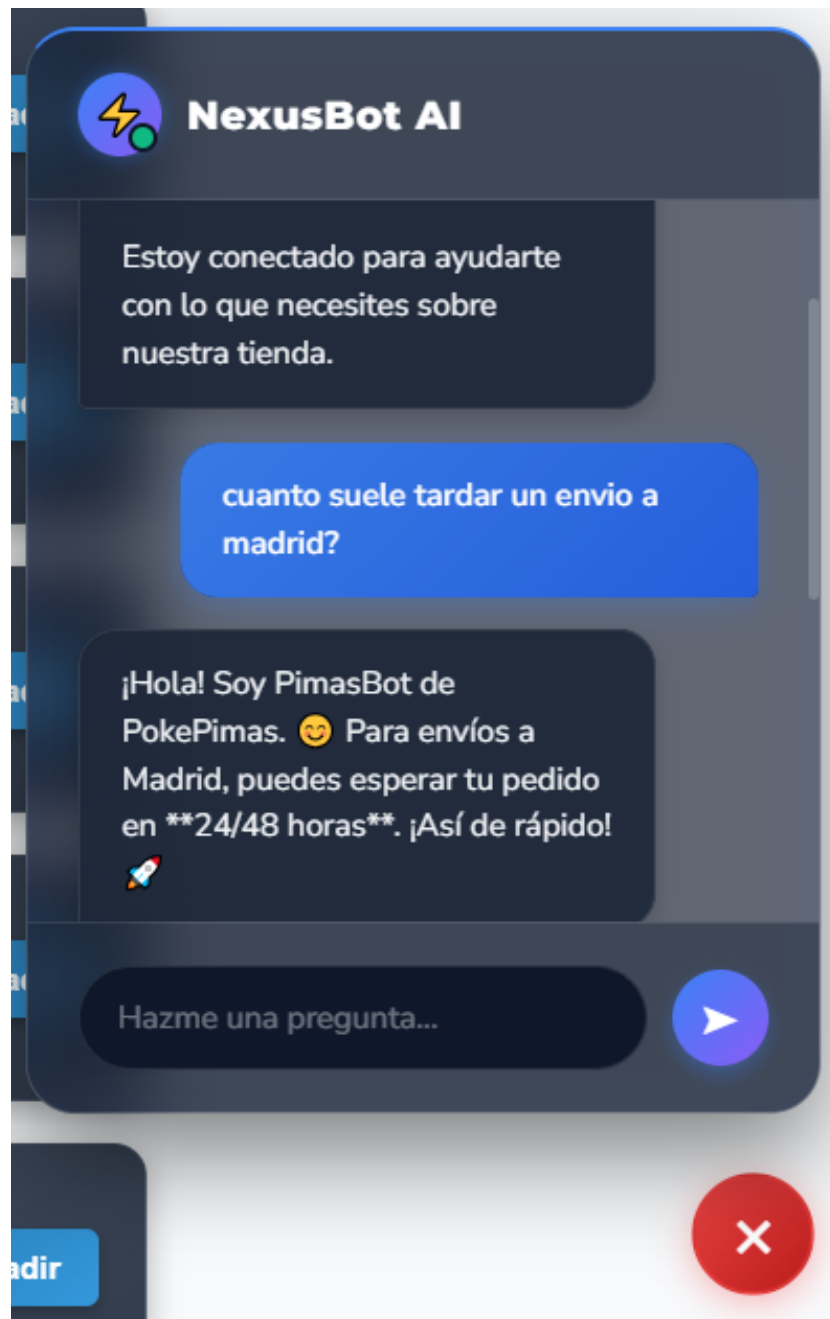


Figura 10: Ejemplo de conversación con el chatbot de la tienda.

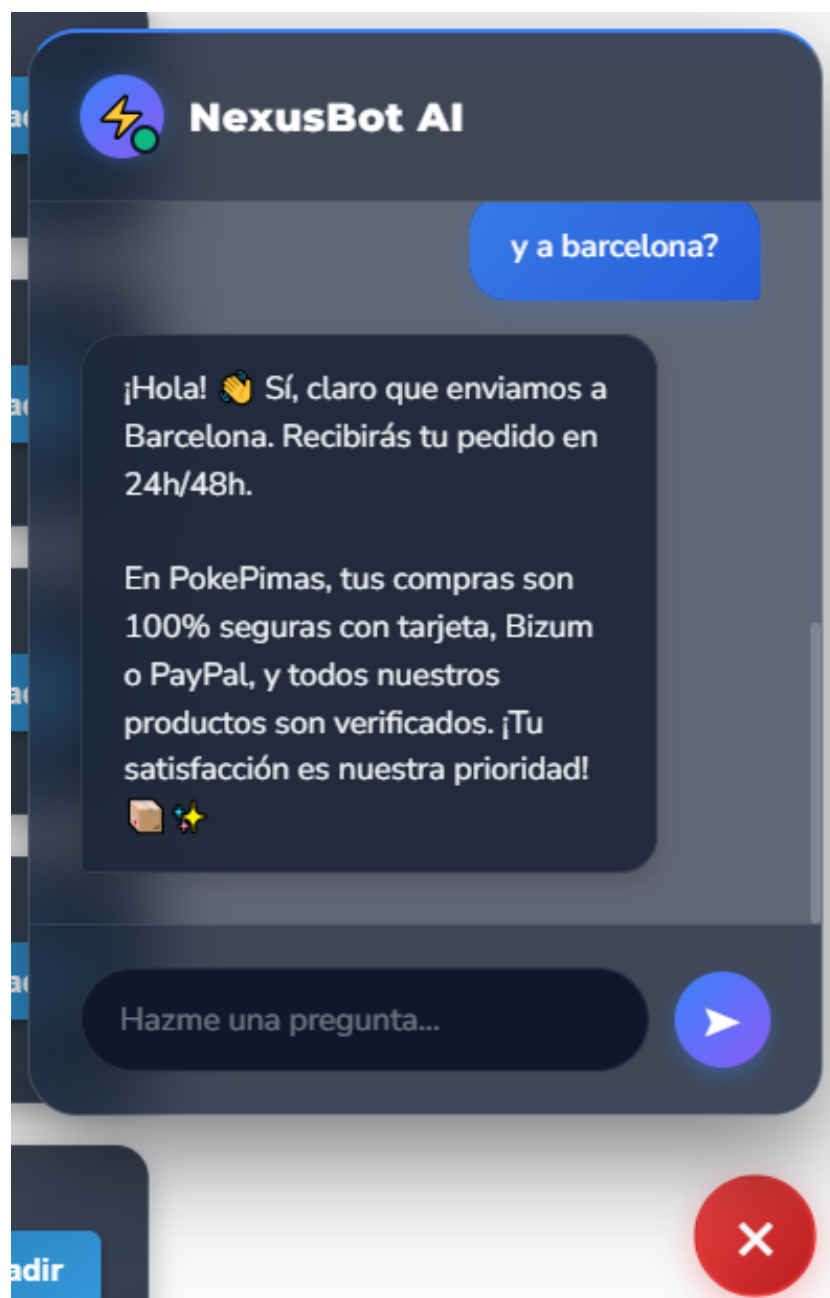


Figura 11: El chatbot resolviendo dudas.

19.5. Atención al Cliente

POKEPIMAS Inicio Cartas Sueltas Productos Sellados Contacto

¿Buscas una carta en específico? ¿Tienes problemas con un pedido?
Ponte en contacto con nuestro equipo de Expertos Pokémon.

Información de Contacto

Contacta con nosotros mediante cualquiera de estas vías y te responderemos en 24h.

- Nuestra Tienda**
ES: Ribera del Tago
Talavera de la Reina
- Soporte Email**
support@pokepimas.tcg.com
info@pokepimas.tcg.com
- Llamadas**
+34 900 123 456
Lun-Vie: 9:00 - 18:00

Síguenos:

Envíanos un mensaje

Tu Nombre Tu Correo Electrónico

Asunto (ej. Duda sobre Charizard)

¿En qué podemos ayudarte?

ENVIAR CONSULTA AHORA -->

Figura 14: Página de contacto.

19.6. Vista Móvil (Diseño Responsive)

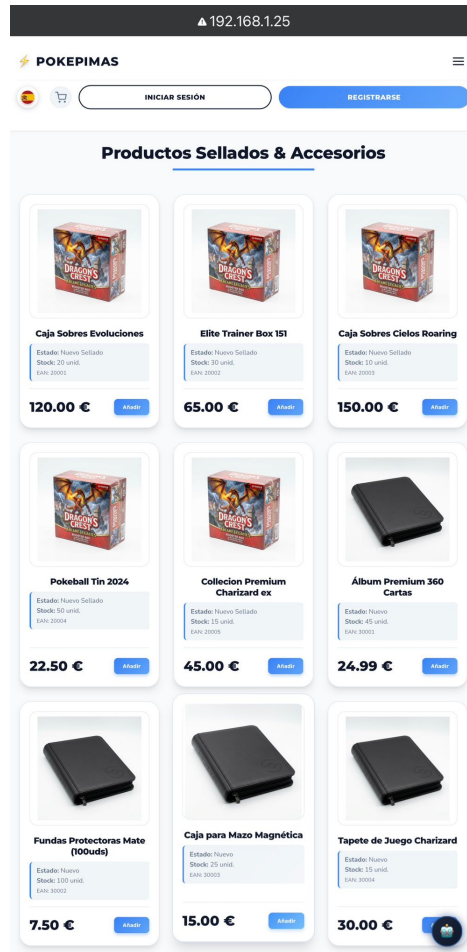


Figura 15: Visualización general de la interfaz adaptada a un teléfono móvil.

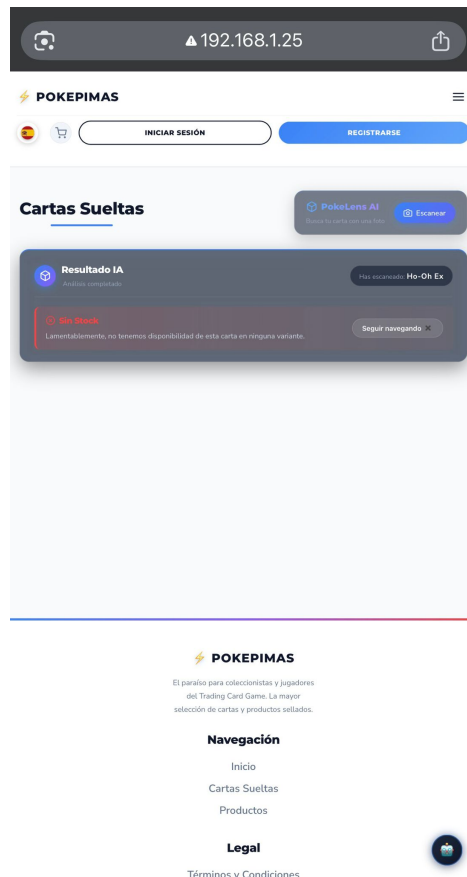


Figura 16: Menú de navegación principal desplegado en formato móvil.

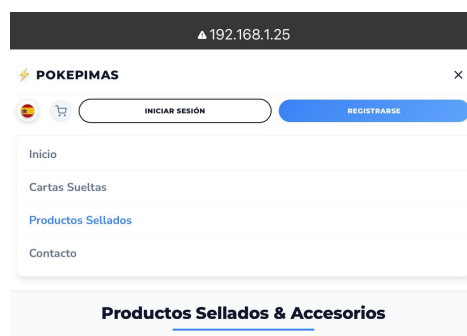


Figura 17: Vista del catálogo de productos y carrito adaptados a la pantalla táctil.